

Digital Agency Criticized for Insufficient Risk Assessment

Date: 09-11-2023

Decision

Public Authorities

Criticism

Supervision / Self-initiated Case

Processing Security

Risk Assessment and Impact Analysis

The Data Protection Agency has investigated the Digital Agency's assessment of risks for citizens logging in with MitID when the agency uses JavaScript to, among other things, display the MitID login client.

Journal Number: 2023-432-0025.

The Data Protection Agency received an inquiry from a citizen on January 20, 2022, regarding the Digital Agency's use of JavaScript as a scripting language in connection with the use of MitID. The inquiry generally stated that JavaScript is outdated and insecure, and that devices, including phones and computers, can easily be hacked if JavaScript is enabled. Additionally, the inquiry referred to the fact that JavaScript has been highlighted as insecure by leading security experts for many years.

Based on the inquiry, the Data Protection Agency chose to initiate a case on its own initiative to investigate the matter.

Summary

The Data Protection Agency has made a decision in a case regarding the Digital Agency's use of JavaScript. The Digital Agency uses JavaScript as a programming language to, among other things, display the MitID login client. The agency decided to investigate the case on its own initiative based on an inquiry from a citizen.

The Data Protection Agency criticized the Digital Agency for failing to demonstrate that the agency had identified the risks that the use of JavaScript entails for the registered individuals, and for not having shown that they had implemented appropriate technical security measures to protect the registered individuals from these risks. This was based on the fact that the Digital Agency had not specifically assessed the risk to the rights of the registered individuals from the use of JavaScript.

Lack of Separate Risk Assessment

The Data Protection Agency stated that it is a prerequisite for the use of a technology such as JavaScript in critical national infrastructure (like MitID) that the data controller conducts a separate risk assessment. This is particularly relevant when it is known that the technology may entail security risks. The Data Protection Agency noted in this context that there are several publicly known abuse scenarios associated with the use of JavaScript. It is therefore the agency's opinion that these risk scenarios should have been addressed where relevant.

In the specific case, the Digital Agency stated that they had not conducted a specific assessment of the risk to the rights of the registered individuals from the use of JavaScript. However, the agency pointed out that a risk assessment had been conducted for MitID, where relevant risks were identified – including overarching risks related to code quality, which JavaScript falls under. The Digital Agency further stated that JavaScript is a globally used programming language for integration with browsers, and that many of the functions and applications that make the internet usable today are coded in some form of JavaScript. The Digital Agency also referred to the fact that in 2013, security measures were assessed when introducing JavaScript in the NemID solution, where the conclusion was that the JavaScript solution was expected to have the same or even a potentially higher level of security than the then-existing solution.

Appropriate Security Measures

Although it does not appear from the General Data Protection Regulation how detailed risk assessments must be, it is the Data Protection Agency's opinion that the data controller is

nevertheless obliged to establish an appropriate level considering the specific and relevant risks, including in relation to the technology used.

“It is essential that a data controller genuinely assesses the use scenarios that a user's personal data undergoes. This also applies even if the solution is based on standard technologies. Any known design weaknesses and attack vectors must be included in the assessments that the data controller makes in order to implement appropriate security measures or redesign the processing workflow. It is also important to keep in mind that a standard technology – does not always – provide the necessary security when the processing concerns scenarios where the user's potential loss of rights is significant,” states Allan Frank, IT security specialist and lawyer at the Data Protection Agency.

1. Decision

After reviewing the case, the Data Protection Agency finds grounds to criticize that the Digital Agency's processing of personal data has not been carried out in accordance with the rules in the General Data Protection Regulation's [1] Article 5, Paragraph 2, cf. Paragraph 1, Letter f, and Article 24, Paragraph 1, cf. Article 32, Paragraph 1.

2. Case Presentation

The Data Protection Agency has, by letters dated February 8 and March 18, 2022, requested statements from the Digital Agency for use in the processing of the case.

The Digital Agency has, by letters dated March 15 and April 27, 2022, submitted statements in the case.

It subsequently appears from the case that the Digital Agency uses JavaScript in connection with the use of MitID, including to display the MitID login client. Citizens must therefore enable JavaScript in their

****browsers, if they wish to use MitID.****

****2.1. Comments from the Agency for Digitization****

The Agency for Digitization has generally stated that JavaScript is a programming language that is widely used around the world for integration with browsers, and that most of the functions and applications that make the internet usable today are coded in some form of JavaScript. The Agency for Digitization has also informed that it has conducted a risk assessment of MitID, and that the agency in the risk assessment has identified relevant risks associated with MitID, including overarching risks related to code quality, which falls under JavaScript. Furthermore, the Agency for Digitization has stated that the agency has addressed risks related to the lack of code review in the risk assessment. In this context, the Agency for Digitization has indicated that the risk to the rights of the data subjects from using the specific technology JavaScript has not been specifically assessed. The Agency for Digitization has further stated that it has implemented appropriate technical and organizational measures to ensure an adequate level of security to protect the rights and freedoms of the data subjects. In this regard, the Agency for Digitization has indicated that it has imposed a number of contractual requirements on Nets as the data processor. Nets is, among other things, obligated to provide an annual audit statement from an independent third party to document compliance with the Agency for Digitization's requirements for information security and requirements regarding the processing of personal data. It is stated in the Agency for Digitization's statements that Nets must provide an audit report of the type ISAE 3000 DK, type I (or equivalent audit report) specifically for all personal data processed in the MitID solution, including for the requirements for information security. The Agency for Digitization has stated that there have been no remarks in the first audit statement received by the agency. Nets is also obligated to continuously assess the MitID solution to ensure that the solution always has an adequate level of security. It is stated in this context that Nets is obliged to continuously make the necessary adjustments if vulnerabilities arise. Furthermore, it is stated that Nets is obligated to ensure code quality and to use the latest technologies and update them. The Agency for Digitization has also indicated that a long list of security requirements has been established to continuously ensure that the solution is secure, updated, etc. This also includes requirements for the security of the use of JavaScript. In this context, the Agency for Digitization has stated that Nets must update their vulnerability assessment of the MitID solution at least every two months based on, among

other things, vulnerability scans. The Agency for Digitization has further stated that the risk assessment for MitID has shown that there is not a high risk to the rights of the data subjects. Finally, the Agency for Digitization has noted that in 2013 it had the security measures assessed regarding the introduction of JavaScript in the NemID solution, where the conclusion from the supplier's external security firm nSense was that "a JavaScript solution will have the same, or perhaps even higher, level of security as the current Applet solution."

****3. Justification for the Data Protection Authority's Decision****

The Data Protection Authority bases its decision on the information provided in the case, that the Agency for Digitization uses JavaScript as a programming language to, among other things, present the MitID login client. The Data Protection Authority further assumes that the Agency for Digitization has not specifically assessed the risk to the rights of the data subjects from using the specific technology JavaScript, but that a risk assessment of MitID has been conducted, where relevant risks have been identified. The General Data Protection Regulation requires, in several respects, that a data controller addresses the risk to the rights and freedoms of the data subjects and can document the considerations and conclusions this has led to. It follows directly from the provisions in Articles 5(1)(f), 24, 25, 32, 33, 34, 35, 36, and 39 that the data controller must address the risk to the rights and freedoms of the data subjects. Furthermore, it follows from both Article 5(2), regarding the principles in Article 5(1), and Article 24 regarding compliance with the entire regulation, that a data controller must be able to demonstrate compliance with data protection rules. Among other things, Articles 25, 35, and 36 require that considerations regarding the involved risks to the rights of the data subjects must take place before the processing begins. It follows from Article 5(1)(f) of the General Data Protection Regulation that personal data must be processed in a manner that ensures adequate security for the personal data in question, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures. The data controller must also be able to demonstrate that the fundamental principles are complied with, which follows from Article 5(2) of the General Data Protection Regulation. Article 32(1) of the General Data Protection Regulation states that the data controller must take appropriate technical and organizational measures to ensure a security level that is appropriate to the risks associated with the data controller's processing of personal data.

It follows from Article 24, paragraph 1 of the General Data Protection Regulation that a data controller must implement appropriate technical and organizational measures to ensure and to be able to demonstrate that the processing is in compliance with the regulation. Thus, the data controller has an obligation to identify the risks that its processing poses to the data subjects and to ensure that appropriate security measures are put in place to protect the data subjects against these risks. The data controller must also be able to demonstrate that personal data is processed in a manner that ensures adequate security for the individuals to whom the data relates. In order for the supervisory authority to assess whether an appropriate level of security has been ensured, it must be documented and explained which risks the data controller has identified and what mitigating measures have been taken to reduce these risks.

The Data Protection Authority notes that the General Data Protection Regulation does not specify how detailed the risk assessment should be. It is the opinion of the Data Protection Authority that the data controller must establish an appropriate level considering the risks that are relevant to the data controller's processing of personal data.

If a supplier, data processor, or available analyses, etc., identifies or indicates specific risk scenarios, it is the opinion of the Data Protection Authority that data controllers should take these assessments into account. This is particularly true when the use of a technology is deemed to involve high risks for the data subjects. At a minimum, there must be a substantiated assessment of why the relationship is not relevant in relation to the processing of personal data that takes place at the data controller.

It is the opinion of the Data Protection Authority that it is a prerequisite for the use of a technology such as JavaScript in connection with critical national infrastructure (such as MitID) that the data controller conducts a separate risk assessment of such technology when it is known that it may involve security

risks. It is noted in this connection that there are several publicly known abuse scenarios associated with the use of JavaScript. In light of this, it is the Authority's opinion that these risk scenarios should have been addressed where relevant.

Furthermore, it is the opinion of the Data Protection Authority that it is not sufficient to refer to an assessment that was made several years ago, where the same technology was used in relation to another solution (here NemID).

On the basis of the above, the Data Protection Authority finds that the Agency for Digitization – by not specifically assessing the risk to the rights of the data subjects from the use of JavaScript – has not demonstrated that it has identified the risks that the use of JavaScript entails for the data subjects, nor does the Authority find it demonstrated that the Agency for Digitization has implemented appropriate technical security measures to protect the data subjects against these risks. The Data Protection Authority therefore criticizes that the Agency for Digitization's processing of personal data has not been carried out in accordance with Article 5, paragraph 2, in conjunction with paragraph 1, letter f, and Article 24, paragraph 1, in conjunction with Article 32, paragraph 1 of the General Data Protection Regulation.

In choosing a response, the Data Protection Authority has emphasized that the Agency for Digitization has conducted a risk assessment of MitID, and that the Agency has, in the risk assessment, addressed the overall risks related to code quality. However, in the opinion of the Data Protection Authority, this risk assessment is not sufficiently detailed, as the Agency has not conducted a specific assessment of the risk to the rights and freedoms of the data subjects from the use of the specific technology JavaScript, which is known to involve security risks. In this connection, the Authority has emphasized that this concerns critical national infrastructure, and that the Agency for Digitization is a professional actor that should have conducted such an assessment.

It is the expectation of the Data Protection Authority that the Agency for Digitization will subsequently conduct a specific assessment of the risk to the rights and freedoms of the data subjects that the use of JavaScript entails for the data subjects. In this connection, the Authority expects the Agency for Digitization to assess whether appropriate measures have been taken in relation to the publicly known security risks that the use of JavaScript entails.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).